2026-05-08 — Gemini ISC2 SSCP Mock Exam (125 Questions + Score)

Date: May 8, 2026
Domains: Domain 1 (Security Operations and Administration) & Domain 2 (Access Controls)

FINAL PERFORMANCE SCORE

Your Final Score: 119 / 125 (95.2%)

Status: Mastery Demonstrated

COMPLETE QUESTION AND ANSWER LOG

*Note: Incorrect answers from your session are highlighted in **RED**.*

Set 1

1. Which component of the CIA Triad is most directly impacted when a Distributed Denial of Service (DDoS) attack prevents legitimate users from reaching a web server?
Answer Options:
- Confidentiality
- Integrity
- **Availability** (Correct)
- Non-repudiation

Rationale: Availability ensures that systems and data are accessible to authorized users when needed, which is exactly what a DDoS attack disrupts.

2. An organization is implementing a security policy where the system owner determines who has access to specific files. Which access control model is being used?
Answer Options:
- Mandatory Access Control (MAC)
- **Discretionary Access Control (DAC)** (Correct)
- Role-Based Access Control (RBAC)
- Attribute-Based Access Control (ABAC)

Rationale: In a DAC model, the owner of the resource has the 'discretion' to grant or deny access to others.

3. In the context of Risk Management, which strategy is being employed if a company decides to outsource its data processing to a third-party provider to avoid the risk of data

breaches on-premises?
Answer Options:
- Risk Avoidance
- Risk Acceptance
- Risk Mitigation
- **Risk Transference** (Correct)
Rationale: Transference involves shifting the financial or operational impact of a risk to another entity, such as through insurance or outsourcing.
4. Which of the following is considered a 'Something You Are' authentication factor?
Answer Options:
- A hardware token generating a one-time password
- **A retinal scan** (Correct)
- A complex alphanumeric password
- A PIN code sent via SMS
Rationale: Biometric data like retinal scans identify unique physical characteristics of the individual.
5. Under the Principle of Least Privilege, what is the primary goal when assigning permissions to a new employee?
Answer Options:
- Providing the employee with full administrative rights to ensure they can complete any task.
- **Granting only the minimum access necessary to perform job functions.** (Correct)
- Ensuring the employee has the same access as their predecessor to maintain consistency.
- Allowing the employee to request access to any resource they encounter during their first week.
Rationale: Limiting access to only what is required reduces the 'attack surface' and potential for accidental or malicious damage.
6. Which type of access control attack involves an attacker trying every possible combination of characters to discover a password?
Answer Options:
- Dictionary Attack
- **Brute-Force Attack** (Correct)
- Social Engineering
- Rainbow Table Attack
Rationale: Brute-force attacks systematically attempt all possible combinations until the correct one is found.
7. In a Mandatory Access Control (MAC) environment, what determines whether a subject can access an object?
Answer Options:
- The subject's group membership
- The object's owner permissions
- **The comparison of security labels and clearance levels** (Correct)
- The time of day and the subject's IP address
Rationale: MAC systems compare the sensitivity label of the object with the clearance level of the user to make access decisions.
8. Which security control is designed to provide 'Accountability' by recording the actions of users within a system?
Answer Options:
- Encryption

- **Auditing** (Correct)
- Firewalls
- Biometrics

Rationale: Auditing and logging record events and actions, allowing security professionals to trace activities back to a specific user.

9. What is the primary difference between Identification and Authentication?

Answer Options:
- Identification is the process of proving who you are; Authentication is claiming an identity.
- **Identification is claiming an identity; Authentication is the process of proving that claim.** (Correct)
- Identification happens after access is granted; Authentication happens before.
- There is no functional difference between the two terms in security.

Rationale: Identification is stating 'I am User A,' while authentication is providing a password or token to prove it.

10. Which of the following is a physical access control?

Answer Options:
- **A fence around a data center** (Correct)
- A complex password policy
- An Access Control List (ACL) on a router
- Security awareness training

Rationale: Fences, locks, and guards are physical barriers that control access to tangible assets.

Set 2

11. Which of the following describes the 'Canon' of the ISC2 Code of Ethics that mandates protecting the commonwealth and infrastructure?

Answer Options:
- Act honorably, honestly, justly, responsibly, and legally.
- **Protect society, the common good, necessary public trust and confidence, and the infrastructure.** (Correct)
- Provide diligent and competent service to principals.
- Advance and protect the profession.

Rationale: This canon establishes the duty of security professionals to the public at large above specific organizational interests.

12. An administrator implements a 'Screened Subnet' to host a web server. Which network zone is this server technically residing in?

Answer Options:
- Intranet
- Extranet
- **Demilitarized Zone (DMZ)** (Correct)
- Dark Net

Rationale: A DMZ or screened subnet acts as a buffer between the untrusted internet and the trusted internal network.

13. Which security concept ensures that a sender of a digital message cannot later deny having sent it?

Answer Options:
- **Accountability** (Your Answer)

- **Non-repudiation** (Correct Answer)
- Integrity
- Availability

Rationale: Non-repudiation uses digital signatures and logs to ensure a party cannot successfully dispute the validity of an action.

14. When configuring a firewall to block all traffic by default and only allow specific ports, which security principle is being applied?

Answer Options:
- **Defense in Depth** (Your Answer)
- **Implicit Deny** (Correct Answer)
- Separation of Duties
- Security through Obscurity

Rationale: Implicit Deny ensures that if no specific rule allows the traffic, it is automatically blocked.

15. A system administrator requires two different people to approve a high-level configuration change. This is an example of:

Answer Options:
- Least Privilege
- Two-Factor Authentication
- **Segregation of Duties** (Correct)
- Mandatory Access Control

Rationale: Segregation (or separation) of duties prevents fraud by requiring multiple individuals to complete a sensitive task.

16. In the Identity Management Lifecycle, what is the 'Provisioning' phase responsible for?

Answer Options:
- Verifying the identity of a user through documents.
- **Creating user accounts and granting initial access rights.** (Correct)
- Revoking access when an employee leaves the company.
- Reviewing logs to see what a user accessed.

Rationale: Provisioning is the process of setting up accounts and resources for a new or existing user.

17. Which type of control is a security camera that records footage for later review after an incident has occurred?

Answer Options:
- Preventative Control
- **Detective Control** (Correct)
- Corrective Control
- Deterrent Control

Rationale: Detective controls identify and record that a security violation has occurred.

18. What is the main goal of a 'Zero Trust' architecture?

Answer Options:
- Eliminating all firewalls to simplify network traffic.
- Trusting all users once they have successfully connected via VPN.
- **Never trusting by default, even if a user is inside the network perimeter.** (Correct)
- Using only biometrics for every single file access.

Rationale: Zero Trust requires continuous verification for every access request, regardless of location.

19. Which authentication protocol allows a user to log into multiple unrelated web applications using their Google or Facebook account?
Answer Options:
- Symmetric Encryption
- RADIUS
- **OAuth 2.0 / OpenID Connect** (Correct)
- LDAP
Rationale: These are standard protocols for federated identity and authorization across web platforms.
20. What does 'clipping level' refer to in the context of system auditing and monitoring?
Answer Options:
- The physical height of a security fence.
- **A threshold for failed events before an alarm is triggered.** (Correct)
- The maximum amount of bandwidth a user can consume.
- The total number of users allowed in a system.
Rationale: A clipping level defines how many times a minor violation can occur before it is flagged as an attack.
21. Which of the following is an Administrative control?
Answer Options:
- Implementing a Screen lock policy through Group Policy.
- **Writing an Acceptable Use Policy (AUP).** (Correct)
- Installing a biometric scanner.
- Updating antivirus signatures.
Rationale: Policies, procedures, and guidelines are the core of administrative controls.
22. In the Biba Integrity Model, the 'Simple Integrity Axiom' states that a subject cannot:
Answer Options:
- Read down to a lower integrity level.
- Read up to a higher integrity level.
- **Read down to a lower integrity level (No Read Down).** (Correct)
- Write down to a lower integrity level.
Rationale: The Simple Integrity Axiom prevents a subject from reading data of lower integrity to prevent 'contamination' of their own information.
23. What is the primary purpose of an 'Exit Interview' from a security perspective?
Answer Options:
- To find out if the employee enjoyed their time at the company.
- **To ensure all company-owned assets are returned and access is revoked.** (Correct)
- To hire a replacement for the employee.
- To determine the employee's new salary at their next job.
Rationale: It serves as a final check to recover hardware, tokens, and reiterate non-disclosure agreements.
24. Which type of physical lock uses a combination of numbered buttons?
Answer Options:
- Warded Lock
- **Cipher Lock** (Correct)
- Pin Tumbler Lock
- Magnetic Lock
Rationale: Cipher locks (or electronic combination locks) require a numeric code entered via a keypad.

25. A user is assigned access to a file based on their role as 'Accountant' and the fact that it is 'Business Hours'. Which model is being used?
Answer Options:
- Role-Based Access Control (RBAC)
- **Attribute-Based Access Control (ABAC)** (Correct)
- Discretionary Access Control (DAC)
- Mandatory Access Control (MAC)
Rationale: ABAC evaluates attributes of the subject (Accountant) and the environment (Business Hours) to make a decision.
26. Which of the following is the most significant risk associated with Single Sign-On (SSO)?
Answer Options:
- Users have to remember too many passwords.
- **If the SSO account is compromised, the attacker has access to all linked systems.** (Correct)
- SSO makes it harder for administrators to manage users.
- SSO requires every application to be on the same server.
Rationale: The single point of failure means a single breach grants broad access to multiple resources.
27. When an employee changes roles within the same company, they often keep their old permissions while gaining new ones. What is this called?
Answer Options:
- **Privilege Creep** (Correct)
- Least Privilege
- Provisioning
- Role-Based Access Control
Rationale: Privilege creep occurs when users accumulate excessive permissions over time as they move through different roles.
28. Which of the following describes 'Logical Access Control'?
Answer Options:
- A security guard at the front gate.
- **Using digital permissions and passwords to protect data.** (Correct)
- Placing a server in a locked cage.
- Lighting in a parking lot.
Rationale: Logical (or technical) controls use software mechanisms to manage access to virtual resources.
29. What is the primary role of a 'Trusted Platform Module' (TPM)?
Answer Options:
- To filter incoming web traffic.
- **To provide hardware-based storage for cryptographic keys.** (Correct)
- To manage user passwords in the cloud.
- To scan for viruses on a hard drive.
Rationale: A TPM is a dedicated chip on a motherboard used for secure boot and key storage.
30. In a Mandatory Access Control system, if a file is labeled 'Secret' and a user has 'Top Secret' clearance, can they read the file?
Answer Options:
- No, they must have exactly 'Secret' clearance.
- **Yes, because their clearance level is equal to or higher than the object's label.** (Correct)

- Only if the owner of the file gives them permission.
- Yes, but only if they are using a specific workstation.

Rationale: The system allows access if the subject's clearance dominates the object's sensitivity label.

31. Which concept describes a scenario where an attacker uses a legitimate user's session to bypass security controls?

Answer Options:
- Piggybacking
- **Session Hijacking** (Correct)
- Brute-Force
- Phishing

Rationale: In digital security, session hijacking involves stealing a valid session token to impersonate a user.

32. An organization conducts a 'Tabletop Exercise'. Which area of security does this primarily support?

Answer Options:
- Physical surveillance
- **Security awareness and incident response training** (Correct)
- Data encryption
- Asset disposal

Rationale: Tabletop exercises involve stakeholders discussing their roles in a simulated incident scenario to improve readiness.

33. Which of the following is a 'Corrective' control?

Answer Options:
- A firewall rule blocking an IP.
- **Restoring data from a known good backup after a ransomware attack.** (Correct)
- An audit log.
- A 'Keep Out' sign.

Rationale: Corrective controls return a system to a normal state after an incident has occurred.

34. What is the primary function of an 'Identity Provider' (IdP) in a federated trust relationship?

Answer Options:
- To host the application the user wants to use.
- **To verify the user's identity and issue a security token.** (Correct)
- To act as a firewall for the user's computer.
- To encrypt the user's hard drive.

Rationale: The IdP (like Okta or Azure AD) authenticates the user and tells the Service Provider who they are.

35. In Asset Management, what is the 'End of Life' (EOL) phase concerned with?

Answer Options:
- The time it takes to boot a server.
- **The point where a manufacturer no longer supports or patches a product.** (Correct)
- The initial design of the software.
- The process of moving data to the cloud.

Rationale: EOL signals that a product is no longer receiving updates, making it a high security risk.

36. Which of the following is an example of 'Defense in Depth'?

Answer Options:

- Using a single, extremely complex password for all systems.
- **Combining a firewall, an IDS, and host-based antivirus.** (Correct)
- Buying two firewalls from the same manufacturer and using the same rules.
- Allowing only one administrator to have access to the server room.

Rationale: Defense in depth involves using multiple overlapping security layers to protect assets.

37. In a 'Rule-Based Access Control' system, access is granted based on:

Answer Options:
- **The user's job title.** (Your Answer)
- **Pre-defined conditions or filters set by an administrator.** (Correct Answer)
- The user's biometric data.
- Individual permissions assigned to the user's name.

Rationale: Rule-based access uses specific rules (like 'if time = 9-5 allow') regardless of individual identity.

38. Which type of physical security control uses two doors where the first must close before the second opens?

Answer Options:
- Turnstile
- **Mantrap** (Correct)
- Bollard
- Jersey Barrier

Rationale: A mantrap (or portal) is a physical access control that traps an individual between two doors to prevent tailgating.

39. What is 'Accountability' dependent on to be effective?

Answer Options:
- Strong encryption.
- **Unique identification of each user.** (Correct)
- A large IT budget.
- Frequent password changes.

Rationale: You cannot hold someone accountable if you don't know exactly who they are through a unique ID.

40. Which of the following is a 'Social Engineering' attack?

Answer Options:
- A SQL Injection attack on a database.
- **Pretexting to trick an employee into giving up their password.** (Correct)
- Installing a keylogger via a USB drive.
- Performing a ping sweep on a network.

Rationale: Social engineering targets human psychology to gain unauthorized access or information.

41. Which security concept is violated if a technician can change a purchase order and also approve the payment for it?

Answer Options:
- Least Privilege
- **Segregation of Duties** (Correct)
- Accountability
- Non-repudiation

Rationale: Failing to separate the power to initiate and authorize a transaction is a classic violation of this principle.

42. What is the primary benefit of using 'Single Sign-On' (SSO) for an end-user?
Answer Options:
- It increases the complexity of each application's password.
- **It allows access to multiple systems with one set of credentials.** (Correct)
- It prevents attackers from ever guessing the password.
- It automatically encrypts all the user's files.
Rationale: SSO improves user experience by requiring only one login for various services.
43. Which type of control is meant to discourage a potential attacker before they even attempt an action?
Answer Options:
- Detective Control
- **Deterrent Control** (Correct)
- Corrective Control
- Technical Control
Rationale: Deterrent controls aim to prevent an action by making it seem too difficult or risky.
44. In the context of 'Internetwork Trust Architectures', what is a 'Transitive Trust'?
Answer Options:
- Trust that must be renewed every 24 hours.
- **If A trusts B and B trusts C, then A trusts C.** (Correct)
- Trust that only allows one-way communication.
- Trust that is manually verified by an administrator every time.
Rationale: Transitive trust allows trust relationships to flow through intermediate domains or systems.
45. Which of the following is a 'Something You Have' authentication factor?
Answer Options:
- A fingerprint.
- **A physical smart card.** (Correct)
- Your mother's maiden name.
- A voice pattern.
Rationale: A smart card or hardware token is a physical object the user must possess to authenticate.
46. What is the primary difference between 'Policies' and 'Procedures'?
Answer Options:
- Policies are technical; Procedures are administrative.
- **Policies state high-level goals; Procedures provide step-by-step instructions.** (Correct)
- Policies are optional; Procedures are mandatory.
- Procedures are written by the CEO; Policies are written by IT.
Rationale: Policies are the 'what' and 'why', while procedures are the 'how'.
47. Which of the following is an example of 'Data Disposal' best practices for high-sensitivity information?
Answer Options:
- Deleting the file and emptying the trash bin.
- **Physical destruction (e.g., shredding or degaussing) of the storage media.** (Correct)
- Reformatting the hard drive.
- Handing the drive to a random third-party recycling center.
Rationale: To ensure data is unrecoverable, the physical media must be destroyed or completely sanitized.
48. What does the 'A' in the IAAA model represent?

Answer Options:
- **Authentication** (Your Answer)
- **Authorization** (Correct Answer)
- Access
- Availability
Rationale: In IAAA, the A's stand for Authentication, Authorization, and Accountability.
49. Which type of control is a 'Security Guard'?
Answer Options:
- Technical
- **Physical** (Correct)
- Logical
- Administrative
Rationale: A guard is a physical presence that controls access to a facility.
50. Which of the following describes a 'Phishing' attack?
Answer Options:
- Trying to crash a server by sending too many requests.
- **Sending fraudulent emails to trick users into revealing sensitive info.** (Correct)
- Scanning for open ports on a router.
- Physically breaking into a server room.
Rationale: Phishing is a social engineering technique used to harvest credentials or install malware.
51. What is the core principle behind 'Least Privilege'?
Answer Options:
- Giving everyone administrative access to reduce help desk calls.
- **Limiting a user's access to only the resources they need for their job.** (Correct)
- Granting access based on the user's seniority in the company.
- Changing passwords every 30 days.
Rationale: Minimizing access reduces the impact of an accidental error or a credential compromise.
52. Which of the following is an example of 'Multi-Factor Authentication' (MFA)?
Answer Options:
- Using two different passwords.
- **Using a password and a fingerprint scan.** (Correct)
- Entering a password twice to confirm it.
- Using a password on your phone and the same password on your PC.
Rationale: MFA requires factors from two or more different categories (Something you know + Something you are).
53. What is 'Configuration Management' (CM) primarily used for?
Answer Options:
- **Maintaining consistency in a system's performance and functional attributes.** (Correct)
- Deleting old user accounts.
- Encrypting emails.
- Conducting employee background checks.
Rationale: CM ensures that systems stay in a known, secure, and documented state over time.
54. In the CIA Triad, which component is ensured by using 'Hashing'?
Answer Options:
- Confidentiality
- **Integrity** (Correct)

- Availability
- Accountability
Rationale: Hashing creates a unique 'fingerprint' of data; if the data changes, the hash won't match.
55. Which of the following is an example of an 'Environmental' physical control?
Answer Options:
- A firewall.
- **A fire suppression system (like FM-200).** (Correct)
- An audit log.
- A password policy.
Rationale: Environmental controls protect the physical infrastructure from fire, flood, or heat.
56. What is the purpose of 'Identity Proofing'?
Answer Options:
- To reset a user's password.
- **To verify that a person is who they claim to be before issuing an identity.** (Correct)
- To encrypt a user's identity in the database.
- To monitor a user's activity for suspicious behavior.
Rationale: Proofing involves checking official documents to establish a trusted identity.
57. Which of the following is a 'Preventative' control?
Answer Options:
- An intrusion detection system (IDS) alert.
- **An intrusion prevention system (IPS) that blocks malicious packets.** (Correct)
- A log file entry.
- A backup restoration process.
Rationale: An IPS actively stops an attack in progress, acting as a preventative measure.
58. In Risk Management, what is 'Residual Risk'?
Answer Options:
- The risk that existed before any controls were applied.
- **The risk that remains after security controls have been implemented.** (Correct)
- The total cost of a data breach.
- The probability that a threat will exploit a vulnerability.
Rationale: Since no control is 100% effective, some risk always remains.
59. Which of the following is a 'Something You Know' authentication factor?
Answer Options:
- A hardware token.
- **A PIN code.** (Correct)
- A retina scan.
- A facial recognition match.
Rationale: A PIN or password is information stored in the user's memory.
60. What is the main purpose of 'Change Management' in security?
Answer Options:
- To prevent any changes from ever occurring.
- **To ensure that changes do not negatively impact security or availability.** (Correct)
- To speed up the deployment of new software.
- To replace all old hardware with new hardware.
Rationale: Change management involves reviewing, testing, and documenting changes to avoid unplanned downtime.

Set 3

61. Which security principle is most directly supported by implementing a system where an employee must use a unique login and all their file modifications are time-stamped in a secure log?
Answer Options:
- Confidentiality
- **Accountability** (Correct)
- Availability
- Redundancy
Rationale: Accountability ensures that actions can be traced back to a specific, uniquely identified entity.
62. A firewall is configured with a rule that states 'If Source IP is 10.0.0.5 and Protocol is HTTP, then Allow.' There are no other rules. What happens to a request from 10.0.0.6?
Answer Options:
- It is allowed by default.
- **It is dropped due to Implicit Deny.** (Correct)
- It is flagged for manual review.
- It is redirected to a guest network.
Rationale: Implicit Deny ensures that any traffic not specifically permitted is blocked by the system's baseline security posture.
63. In the Bell-LaPadula model, the *-Property (Star Property) prevents which of the following actions?
Answer Options:
- A subject at a higher security level reading data at a lower level.
- A subject at a lower security level reading data at a higher level.
- **A subject at a higher security level writing data to a lower level.** (Correct)
- A subject at a lower security level writing data to a higher level.
Rationale: The Star Property enforces 'No Write Down' to prevent the unauthorized disclosure of sensitive information to lower-clearance areas.
64. Which of the following is the most effective way to ensure Non-repudiation in digital communications?
Answer Options:
- Using a strong, complex password for email accounts.
- **Applying a digital signature using the sender's private key.** (Correct)
- Implementing Two-Factor Authentication (2FA).
- Encrypting the entire message with a symmetric key.
Rationale: Digital signatures provide proof of both integrity and the identity of the sender.
65. An organization uses a system that checks if a user is in the 'HR' group AND if they are connecting from the 'Internal_WiFi' network before granting access. This is an example of:
Answer Options:
- Discretionary Access Control (DAC)
- Mandatory Access Control (MAC)
- Rule-Based Access Control
- **Attribute-Based Access Control (ABAC)** (Correct)
Rationale: ABAC evaluates specific attributes of the user and the environment to determine

access.

66. Which risk management term describes the potential for a threat to exploit a weakness in a system?

Answer Options:
- Vulnerability
- Exposure
- Likelihood
- **Risk** (Correct)

Rationale: Risk is the intersection of a threat, a vulnerability, and the potential impact of an exploit.

67. A security professional is evaluating the 'MTBF' of a new server. What is the primary concern here?

Answer Options:
- Confidentiality
- Integrity
- **Availability** (Correct)
- Authentication

Rationale: Mean Time Between Failures (MTBF) measures the predicted elapsed time between failures, impacting availability.

68. Which of the following is an example of a technical control used for the purpose of 'Deterrence'?

Answer Options:
- **A login banner warning that all activity is monitored.** (Correct)
- A complex password policy enforced by the OS.
- An automated backup system.
- A firewall blocking all inbound SSH traffic.

Rationale: Technical banners serve to warn potential intruders of the legal consequences, which acts as a deterrent.

69. In the IAAA model, which step is responsible for determining which specific folders and files a user can edit after they have logged in?

Answer Options:
- Identification
- Authentication
- **Authorization** (Correct)
- Accountability

Rationale: Authorization defines the rights and permissions granted to an authenticated identity.

70. What is the primary objective of 'Need to Know' in an access control environment?

Answer Options:
- To ensure that all employees are aware of the company's security policy.
- To provide users with access to all data within their security clearance level.
- **To restrict access to specific information required to perform a specific job function.** (Correct)
- To allow the system owner to grant access at their own discretion.

Rationale: Need to Know ensures that even if a user has the clearance, they only see information necessary for their current duties.

71. Which of the following describes a 'Type II Error' in biometric systems?

Answer Options:
- False Rejection Rate (FRR)

- **False Acceptance Rate (FAR)** (Correct)
- Crossover Error Rate (CER)
- Failure to Enroll (FTE)

Rationale: A Type II error occurs when the system incorrectly identifies an unauthorized person as an authorized user.

72. An administrator is setting up 'Geofencing' to restrict access to a mobile application. This is an example of which authentication factor?

Answer Options:
- Something you are
- Something you have
- **Somewhere you are** (Correct)
- Something you know

Rationale: Geofencing uses GPS or network location to verify the physical position of the subject.

73. Which ISC2 Code of Ethics canon is primarily concerned with professional growth and the reputation of the security community?

Answer Options:
- Protect society, the common good, and the infrastructure.
- Act honorably, honestly, justly, responsibly, and legally.
- Provide diligent and competent service to principals.
- **Advance and protect the profession.** (Correct)

Rationale: This canon encourages sharing knowledge, mentoring others, and maintaining the profession's integrity.

74. What is the primary difference between a 'Risk Tabletop Exercise' and a 'Risk Assessment'?

Answer Options:
- A tabletop exercise is a quantitative analysis; an assessment is qualitative.
- **A risk assessment identifies and analyzes risks; a tabletop exercise tests the response to those risks.** (Correct)
- Assessments are only for technical staff; tabletops are only for management.
- Tabletops are mandatory by law; assessments are optional.

Rationale: Assessments find the problems, while tabletop exercises are simulations used to practice response.

75. In the context of the Identity Management Lifecycle, what is 'Identity Proofing'?

Answer Options:
- Using a password to log into a computer.
- **The process of verifying a person's physical identity before granting digital credentials.** (Correct)
- Encrypting the database that stores user names.
- Auditing user logs to find imposters.

Rationale: Identity proofing involves checking real-world documents to ensure the person is who they claim to be.

76. Which of the following is a drawback of using Mandatory Access Control (MAC)?

Answer Options:
- It is less secure than Discretionary Access Control (DAC).
- **It is complex to implement and maintain due to labeling requirements.** (Correct)
- It allows users to share files too easily.
- It does not support the Principle of Least Privilege.

Rationale: Every object and subject must be meticulously labeled and cleared, requiring significant effort.

77. Which of the following best describes 'Defense in Depth'?

Answer Options:
- Using a single very strong firewall at the edge of the network.
- Placing all sensitive servers in a basement for physical security.
- **Implementing a series of overlapping security controls at different layers.** (Correct)
- Using only open-source software to avoid vendor backdoors.

Rationale: Layered security ensures that if one control fails, others are in place to stop the threat.

78. A company decides to accept the risk of a minor data leak because the cost of the security software is higher than the potential loss. This is an example of:

Answer Options:
- Risk Transference
- Risk Avoidance
- **Risk Acceptance** (Correct)
- Risk Mitigation

Rationale: Risk acceptance is a conscious decision to deal with the consequences because mitigation is not cost-effective.

79. What is the primary role of an 'Authorization' policy in an Access Control system?

Answer Options:
- To verify that the password matches the username.
- **To define the specific actions and resources available to a user.** (Correct)
- To record every file that a user opens.
- To provide a user with a unique identification number.

Rationale: Authorization policies determine what an authenticated user is permitted to do.

80. Which type of control is a policy that requires all employees to attend an annual security awareness training session?

Answer Options:
- Technical Control
- **Administrative Control** (Correct)
- Physical Control
- Detective Control

Rationale: Administrative (or management) controls include policies, procedures, and training programs.

81. Which trust model is characterized by a central authority that issues digital certificates to all participants?

Answer Options:
- Web of Trust
- **Hierarchical Trust (PKI)** (Correct)
- Peer-to-Peer Trust
- Bridge Trust

Rationale: A Public Key Infrastructure (PKI) relies on a central Certificate Authority (CA) to manage trust.

82. What is 'Privilege Bracketing'?

Answer Options:
- Giving a user admin rights only during their specific shift hours.
- **The practice of starting and ending an operation with the minimum necessary**

privileges. (Correct)
- Creating different tiers of administrators in an organization.
- Grouping users into brackets based on their security clearance.
Rationale: Bracketing ensures that a process only 'elevates' its privileges for the brief moment it needs them.
83. Which of the following attacks targets the 'Integrity' of data?
Answer Options:
- Eavesdropping on a wireless network.
- **A Man-in-the-Middle (MitM) attack that modifies a bank transfer amount.** (Correct)
- A DDoS attack against a DNS server.
- Shoulder surfing to see a user's password.
Rationale: By altering the data in transit, the attacker has directly violated integrity.
84. What is the primary risk of a 'Guest Account' being left enabled on a corporate network?
Answer Options:
- It takes up too much disk space.
- **It provides a low-barrier entry point for an attacker to gain a foothold.** (Correct)
- It makes the network run slower.
- It prevents legitimate administrators from logging in.
Rationale: Anonymous or widely known credentials allow attackers to bypass initial identification hurdles.
85. Which document defines the specific responsibilities of each party in a Cloud Service relationship (e.g., between a company and Amazon Web Services)?
Answer Options:
- Acceptable Use Policy (AUP)
- Service Level Agreement (SLA)
- **Shared Responsibility Model** (Correct)
- Non-Disclosure Agreement (NDA)
Rationale: The Shared Responsibility Model outlines which security tasks are the provider's and which are the customer's.
86. Which of the following is a drawback of using Discretionary Access Control (DAC)?
Answer Options:
- It is too rigid for dynamic environments.
- **It is vulnerable to 'Trojan Horse' attacks where a user's permissions are misused by malicious software.** (Correct)
- It requires expensive hardware to implement.
- Users cannot share their files with anyone else.
Rationale: Since the owner has full discretion, malware can change permissions without system oversight.
87. What is the function of a 'Honeycomb' or 'Honeypot' in a network?
Answer Options:
- To encrypt all traffic automatically.
- **To act as a decoy to lure and study attackers.** (Correct)
- To speed up the internet connection.
- To store backup tapes in a secure location.
Rationale: Honeypots are trap systems designed to divert attackers and collect threat intelligence.
88. Which protocol is commonly used to provide centralized Authentication,

Authorization, and Accounting (AAA) for network access (e.g., VPN or Dial-up)?
Answer Options:
- HTTP
- **RADIUS** (Correct)
- SMTP
- FTP
Rationale: Remote Authentication Dial-In User Service (RADIUS) is the standard for centralized AAA management.
89. In the Biba Integrity Model, the *-Integrity Axiom (Star Integrity Axiom) states that:
Answer Options:
- A subject cannot read down.
- **A subject cannot write up.** (Correct)
- A subject cannot read up.
- A subject cannot write down.
Rationale: The Star Integrity Axiom prevents a subject from writing data to a higher integrity level.
90. Which of the following is an example of an 'Administrative' physical security control?
Answer Options:
- A high-security lock on the server room door.
- **A policy requiring guards to verify government IDs for all visitors.** (Correct)
- A motion-activated floodlight.
- A perimeter fence.
Rationale: Policies and procedures governing physical security are administrative controls.
91. Which type of control is a 'Security Audit' performed by an outside firm?
Answer Options:
- Preventative Control
- **Detective Control** (Correct)
- Corrective Control
- Technical Control
Rationale: Audits are used to discover deviations from policy or identify historical breaches.
92. What is the primary benefit of 'Federated Identity' for an organization?
Answer Options:
- It eliminates the need for any firewalls.
- **It allows users to use their existing credentials to access resources in another organization's domain.** (Correct)
- It makes passwords impossible to crack.
- It automatically backup all user data.
Rationale: Federation enables seamless access across organizational boundaries without needing separate accounts.
93. Which security concept is violated if a user can successfully modify a system's audit logs to hide their activities?
Answer Options:
- Confidentiality
- **Accountability** (Your Answer)
- **Integrity** (Correct Answer)
- Availability
Rationale: Modifying logs unauthorizedly is a direct violation of data integrity.
94. A company requires employees to physically sign a sheet when entering the building.

Which part of the IAAA model does this represent?
Answer Options:
- **Identification** (Correct)
- Authentication
- Authorization
- Non-repudiation
Rationale: Writing your name on a sheet is stating who you are, which is identification.
95. What is 'Job Rotation' used for from a security perspective?
Answer Options:
- To keep employees from getting bored with their tasks.
- **To increase the likelihood of discovering fraudulent activities performed by an employee.** (Correct)
- To ensure that everyone can do every job in the company.
- To reduce the salary costs of specialized technicians.
Rationale: If an employee is committing fraud, a different person taking over is more likely to spot it.
96. Which of the following is a physical security control designed for 'Assessment' (Detection)?
Answer Options:
- A barbed-wire fence.
- **A Closed-Circuit Television (CCTV) system.** (Correct)
- A steel-reinforced door.
- A 'Private Property' sign.
Rationale: Cameras allow personnel to detect an intrusion as it happens or review it later.
97. What is the 'Principle of Least Privilege' applied to an application's service account?
Answer Options:
- Running the service account with full 'Domain Admin' rights.
- **Restricting the service account to only the specific folders and registry keys it needs to run.** (Correct)
- Deleting the service account every time the server restarts.
- Allowing the service account to change its own password.
Rationale: Least privilege applies to accounts and processes as much as to human users.
98. Which of the following is a 'Corrective' administrative control?
Answer Options:
- **A Disaster Recovery Plan (DRP).** (Correct)
- A security guard at the front gate.
- A firewall software update.
- An audit of last year's financial records.
Rationale: A DRP provides administrative instructions for how to restore operations after failure.
99. In Risk Management, what is 'Inherent Risk'?
Answer Options:
- The risk that remains after all controls are in place.
- **The risk that exists in the absence of any security controls.** (Correct)
- The risk of an employee making a mistake.
- The financial cost of a risk being realized.
Rationale: Inherent risk is the raw risk level associated with an asset before safeguards are applied.
100. Which of the following describes 'Logical Separation' in a network?

Answer Options:
- Placing servers in different physical rooms.
- **Using Virtual LANs (VLANs) to isolate traffic between departments.** (Correct)
- Cutting the ethernet cables to prevent communication.
- Turning off the power to the switches.
Rationale: Logical separation uses software and protocols to isolate data sharing physical hardware.

Set 4

101. A security professional is tasked with ensuring that information does not flow from a higher security level to a lower security level to protect confidentiality. Which formal model should they implement?
Answer Options:
- Biba Model
- **Bell-LaPadula Model** (Correct)
- Clark-Wilson Model
- Brewer-Nash Model
Rationale: The Bell-LaPadula model is designed to enforce confidentiality by preventing 'write-down' and 'read-up'.
102. Which of the following is a primary risk when implementing a 'Bring Your Own Device' (BYOD) policy in a secure environment?
Answer Options:
- Increased hardware procurement costs
- **Data exfiltration through unmanaged endpoints** (Correct)
- Elimination of the need for Multi-Factor Authentication
- Improved visibility into user behavior
Rationale: Unmanaged personal devices may lack company-mandated controls, increasing data leak risks.
103. An organization uses an XML-based framework for communicating user authentication and authorization data between an Identity Provider and a Service Provider. What is this called?
Answer Options:
- **RADIUS** (Your Answer)
- **SAML** (Correct Answer)
- LDAP
- Kerberos
Rationale: Security Assertion Markup Language (SAML) is the standard XML framework for exchanging security assertions.
104. Which of the following is the most effective control to prevent an attacker from successfully using a stolen session token?
Answer Options:
- Stronger password complexity requirements
- **Shortening the session timeout duration** (Correct)
- Implementing a lockout policy after three failed attempts
- Using a screened subnet
Rationale: Reducing the 'time to live' for a token limits the window of opportunity for an attacker.
105. In a risk assessment, a 'Threat' is best defined as:

Answer Options:
- A flaw or weakness in system security procedures.
- The likelihood that a specific event will occur.
- **Any potential occurrence that may cause an undesirable outcome.** (Correct)
- The monetary loss expected from an incident.
Rationale: A threat is an outside force or event that could exploit a vulnerability.

106. Which component of the IAAA model is most directly supported by a policy that forbids the sharing of administrative accounts?
Answer Options:
- Identification
- **Accountability** (Correct)
- Authorization
- Availability
Rationale: Shared accounts make it impossible to definitively link an action to a specific individual.

107. An administrator uses a 'Jump Server' to manage internal servers from a remote location. What security principle is this primarily an example of?
Answer Options:
- **Defense in Depth** (Correct)
- Least Privilege
- Implicit Deny
- Non-repudiation
Rationale: Adding an intermediate, hardened system creates multiple layers of security.

108. Which of the following is a 'Something You Know' factor often used in bank ATMs?
Answer Options:
- The ATM card
- **A Personal Identification Number (PIN)** (Correct)
- A fingerprint scan
- The ATM's location
Rationale: A PIN is information that only the user should know and memorize.

109. Which backup strategy requires the most time to restore but the least amount of storage space for daily backups?
Answer Options:
- Full Backup
- Differential Backup
- **Incremental Backup** (Correct)
- Mirroring
Rationale: Incrementals only store changes since the last backup, requiring every daily tape for restore.

110. In the context of the Bell-LaPadula model, the 'Simple Security Property' is often summarized as:
Answer Options:
- No Read Down
- **No Write Down** (Your Answer)
- **No Read Up** (Correct Answer)
- No Write Up
Rationale: The Simple Security Property prevents a subject from reading an object at a higher security level.

111. Which of the following describes the 'Due Diligence' of a security professional?
Answer Options:
- The act of implementing the actual security controls.
- **The ongoing research and investigation necessary to understand risks.** (Correct)
- Signing an NDA before starting a project.
- Providing the minimum necessary access to users.
Rationale: Due Diligence is the 'checking' or research phase to ensure right decisions are made.
112. An attacker uses a device to intercept communication between a user's browser and a server, pretending to be the server to the user and the user to the server. What is this?
Answer Options:
- Replay Attack
- **Man-in-the-Middle (MitM) Attack** (Correct)
- Denial of Service
- Buffer Overflow
Rationale: A MitM attack occurs when an attacker inserts themselves into a stream to eavesdrop or alter data.
113. Which type of fire suppression system is most appropriate for a data center containing high-value electronic equipment?
Answer Options:
- Wet Pipe Sprinkler
- **Clean Agent System (e.g., FM-200)** (Correct)
- Dry Pipe Sprinkler
- Standard ABC Fire Extinguisher
Rationale: Clean agents are gaseous, non-conductive, and leave no residue, making them safe.
114. When an organization uses a 'Federated' identity model, who is responsible for the 'Identity Proofing' of the user?
Answer Options:
- The Service Provider (SP)
- **The Identity Provider (IdP)** (Correct)
- The end-user themselves
- The Certificate Authority
Rationale: The IdP is the authoritative source that verifies the user's identity before issuing credentials.
115. Which of the following is a physical security control used for 'Deterrence'?
Answer Options:
- A motion-detecting alarm
- **A 'Warning: Trespassers will be Prosecuted' sign** (Correct)
- A biometric hand scanner
- A fire suppression system
Rationale: Signs are intended to discourage potential attackers by informing them of consequences.
116. What is the primary objective of a 'Vulnerability Scan'?
Answer Options:
- To exploit a system and gain root access.
- **To identify known security weaknesses and missing patches.** (Correct)
- To prove to management that the network is 100% secure.
- To provide a step-by-step procedure for a disaster recovery.
Rationale: Vulnerability scans are automated tools used to find 'open doors' and unpatched

software.
117. A user is assigned access to a printer based on the attribute 'Department = Marketing'. What type of access control is being used?
Answer Options:
- Discretionary Access Control (DAC)
- Mandatory Access Control (MAC)
- **Attribute-Based Access Control (ABAC)** (Correct)
- Rule-Based Access Control
Rationale: ABAC uses characteristics of the subject (department) to make access decisions.
118. Which phase of the incident response process involves the removal of the threat from the environment?
Answer Options:
- Detection
- Containment
- **Eradication** (Correct)
- Recovery
Rationale: Eradication is the process of deleting malware or closing the vulnerability used.
119. In the Clark-Wilson integrity model, what is used to ensure that only authorized transformations are performed on data?
Answer Options:
- **Security Labels** (Your Answer)
- **Transformation Procedures (TPs)** (Correct Answer)
- Access Control Lists (ACLs)
- Encryption Keys
Rationale: TPs are the only way data can be changed in Clark-Wilson to ensure integrity.
120. Which of the following is an example of an 'Environmental' threat?
Answer Options:
- A SQL injection attack
- **An earthquake destroying a server room** (Correct)
- An employee stealing data
- A weak password policy
Rationale: Environmental threats include natural disasters and infrastructure failures.
121. What does 'Provisioning' refer to in the Identity Management Lifecycle?
Answer Options:
- Deleting a user's account after they leave.
- Recording a user's activities in a log file.
- **Creating an account and assigning initial access rights to a new user.** (Correct)
- Proving a user's identity with a smart card.
Rationale: Provisioning is the 'onboarding' phase of creating and arming an identity.
122. Which metric is used to determine the total expected monetary loss from a single risk event?
Answer Options:
- Exposure Factor (EF)
- **Single Loss Expectancy (SLE)** (Correct)
- Annualized Rate of Occurrence (ARO)
- Annualized Loss Expectancy (ALE)
Rationale: SLE ($Asset Value \times EF$) provides the dollar value for one occurrence.
123. Which form of biometric scanning is considered the least intrusive to the user but

still highly accurate?
Answer Options:
- Retinal Scan
- **Iris Scan** (Correct)
- DNA Sampling
- Fingerprint Scan
Rationale: Iris scans can be done from a distance with a standard camera, making it less intrusive.
124. What is the primary security goal of 'Separation of Duties'?
Answer Options:
- To speed up administrative tasks.
- **To prevent any single individual from being able to perform a sensitive action alone.** (Correct)
- To ensure that every employee is trained in every job role.
- To make passwords easier to remember.
Rationale: By splitting a task between two people, you require collusion to commit fraud.
125. Which of the following is a drawback of using Symmetric Encryption for large numbers of users?
Answer Options:
- It is much slower than Asymmetric Encryption.
- **Key management becomes difficult because every pair of users needs a unique key.** (Correct)
- It cannot provide confidentiality.
- It requires a Certificate Authority (CA) to work.
Rationale: As the number of users grows, the number of keys required increases exponentially.

FULL 125-QUESTION PRACTICE RECORD COMPLETE